

CyberDefense Pro 2.0

2.2.1 Risk Management Principles

A risk management program works to identify risks and determine how to minimize their likelihood or impact. After identifying risks, the next step is to handle them using different responses. Risk management principles include:

- Minimize an organization's exposure to cyber threats.
- Protect an organization's assets from unauthorized access, theft, or damage.
- Help organizations comply with data security and privacy regulations and standards.

This lesson covers the following topics:

- Cybersecurity leadership concepts
- Risk identification
- Risk response strategies
- Risk monitoring and evaluation

Cybersecurity Leadership Concepts

It is essential to understand the basic concept of leadership in the cybersecurity field. A cybersecurity leader is responsible for creating a vision and setting goals for a team to secure an organization's assets. Additionally, they must understand the technical and legal aspects of the industry and be able to advise on the best approaches for providing appropriate levels of protection. Leaders must have a deep understanding of the industry and its nuances and the ability to make decisions quickly and confidently. A leader in cybersecurity must also possess strong interpersonal skills to communicate effectively with a wide range of technical and non-technical stakeholders.

Risk Identification

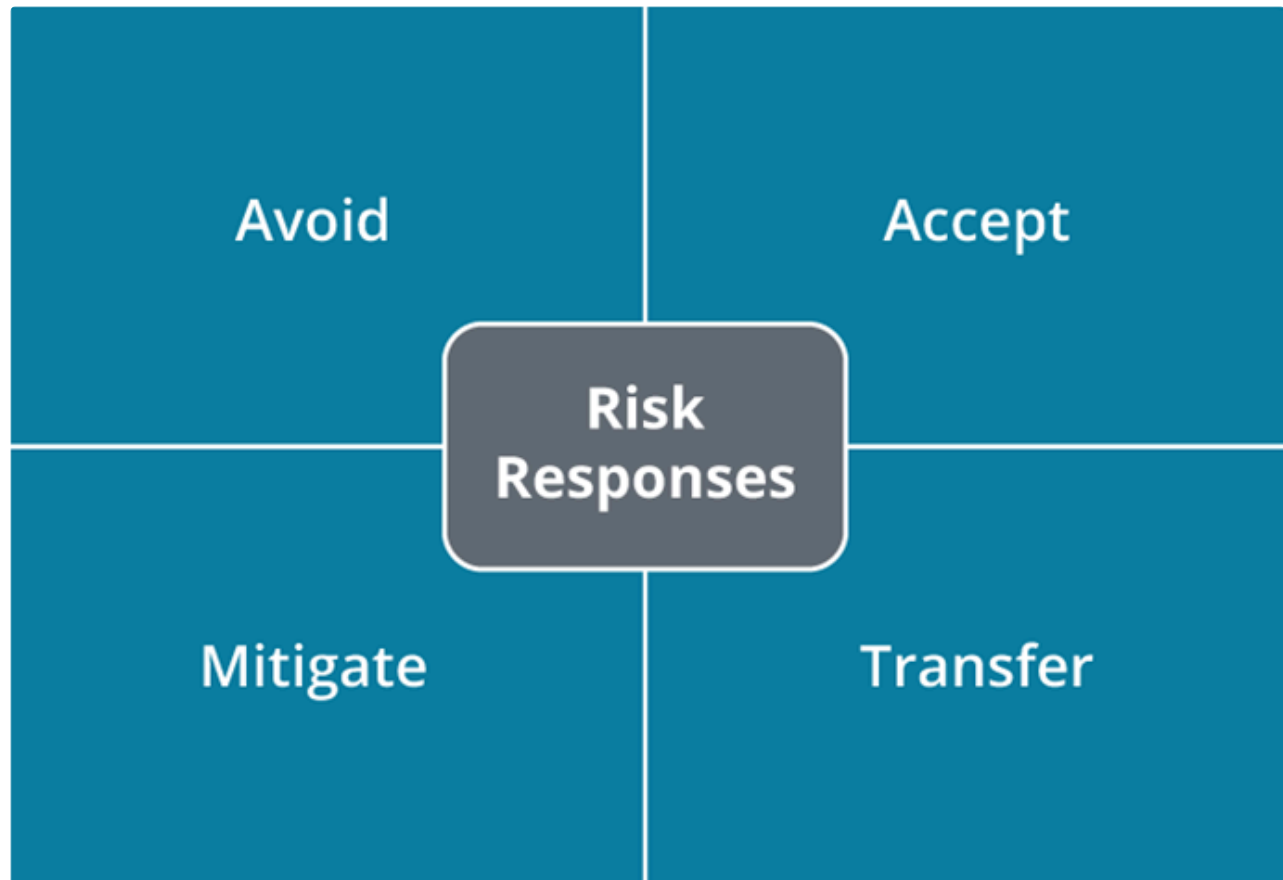
Risk identification involves examining all aspects of an organization's operations, processes, and activities to identify potential hazards, vulnerabilities, or weaknesses that may lead to negative consequences. This process allows organizations to take proactive measures to mitigate these risks and prevent or reduce the negative consequences they may cause.

Risk identification includes identifying potential risks or threats to an organization's assets, including:

- People
- Systems
- Data
- Finances

Risk Response Strategies

After identifying risks, the next step is to handle them using different responses. This process involves analyzing the likelihood and impact of each risk and selecting an appropriate response based on its severity and importance. Responses to risk fall into four distinct categories:



▼ Description

The image is a simple rectangular diagram divided into four equal quadrants. At the center of the diagram, there is a box labeled "Risk Responses." Each surrounding quadrant contains one of the four main risk response strategies:

- The top-left quadrant says "Avoid."

- The top-right quadrant says "Accept."
- The bottom-left quadrant says "Mitigate."
- The bottom-right quadrant says "Transfer."

These terms represent common options for responding to risk in project management, information security, or general risk assessment:

- **Avoid:** Taking action to remove the risk or change plans to sidestep the threat.
- **Accept:** Acknowledging the risk and deciding to live with it.
- **Mitigate:** Taking steps to reduce the severity or likelihood of the risk.
- **Transfer:** Shifting the risk to a third party, such as by outsourcing or purchasing insurance.

The visual emphasizes that these are the four main strategies used to address risk.

Risk Type	Description
Avoid	Risk avoidance often means that you stop doing an activity that is risk-bearing. For instance, risk managers may discover a software application has numerous high-severity security vulnerabilities. After reporting this new finding and providing context to the risks, the governance team may decide that the cost of maintaining the application, or the probability of catastrophic failure due to the newly discovered vulnerabilities, is not worth its benefit and so choose to have it decommissioned.
Accept	Risk acceptance means continuing to operate without change after evaluating an identified risk item. The risk item could be related to software, hardware, or existing processes. We must consider risk in all we do; even simple daily tasks involve risks. But despite this, we are still productive and largely safe so long as we are aware of risks and act within safe limits. Helping organizations operate this way is precisely the goal of risk management—to help contain threats within carefully constructed and mutually agreed-upon boundaries because it is impossible to eliminate risk.
Mitigate	Risk mitigation describes reducing exposure to risk items by implementing mitigating controls to ensure that technical business operations are safe. For example, there are many potential security issues associated with web applications. Since web applications are critical to many business processes, we must determine how to operate them safely while meeting the organization's needs. To do this, we use various means to improve the web application's safety and security through mitigating controls. By implementing effective mitigating controls, we can reduce the overall risk. We implement mitigating

Risk Type	Description
	controls until risk levels are reduced to a level deemed "acceptable" by risk managers and governance teams.
Transfer	Risk transference (or sharing) means assigning risk to a third party, which is most typically accomplished through insurance policies. Insurance transfers financial risks to a third party. This is an essential strategy as the cost of data breaches and other cybersecurity events can be extremely high and result in bankruptcy.

Despite the presence of mitigating controls, some risks may still be troublesome. It could also be that mitigating controls are not available to help reduce the risk level. For example, a different risk response might be warranted, like avoidance. Circumstances may warrant a risk exception if a different risk response is not reasonable or feasible. Issuing a risk exception is a serious decision. It must include careful documentation identifying why the risks are concerning and specific justifications describing why an exception is warranted. The explanation should document the dates when the decision to issue an exception was made and include the signatures of all involved.

Risk Monitoring and Evaluation

Risk monitoring and evaluation are critical components of an effective risk management program. Risk monitoring is continually assessing and monitoring potential risks, identifying changes in the risk landscape, and detecting emerging threats or vulnerabilities. This requires ongoing data analysis from internal and external sources, such as threat intelligence feeds, incident reports, and regulatory updates. By monitoring risks continuously, organizations can proactively identify potential issues and take corrective action before they escalate into major problems.

Risk evaluation involves assessing the likelihood and potential impact of identified risks and prioritizing them based on their significance level. This process requires careful analysis of risk data to determine the probability of an event occurring and the potential impact on organizational operations, reputation, and financial stability. Risk evaluation enables organizations to focus on managing the most critical risks and implementing appropriate controls to mitigate their potential impact. Risk monitoring and evaluation provide a comprehensive view of an organization's risk landscape, enabling decision-makers to make informed choices about risk management strategies and ensure ongoing business resilience.

Copyright © CompTIA, Inc. All rights reserved.